

Research Question and Summary

Q: What are the current challenges to healthcare privacy in the digital age, and what solutions are there to mitigate the risk of privacy violations of an individual's healthcare information?

- Summary: Privacy in the healthcare system remains a pressing issue: healthcare information remains one of the most personal and private aspects of an individual's identity. Nevertheless, in this digitized world, there are increasing concerns as to the security of that private information. The rise of digital technologies has led to an expansion of entities involved in the healthcare system beyond those traditionally considered as part of the healthcare ecosystem. Third-party apps, digital portals, watches, and health care technology (like fall sensors) all now collect deeply personal data of an individual's healthcare identity. Some regulations, such as HIPAA, do exist, but they fail to entirely encapsulate the ever-expanding digital ecosystem that the healthcare ecosystem has decided to embrace. Misuse of healthcare data can be classified into multiple categories, including but not limited to unauthorized access, selling of data to third parties, and the use of personal data to abuse the patient.

History of Data Privacy in Health Care

- Privacy Act of 1974:** The first attempt to regulate healthcare privacy, governing only federal health records and leaving private healthcare providers entirely unregulated.
- HIPAA (1996):** Established the first comprehensive federal framework for patient privacy, requiring three covered entities (healthcare providers, insurers, and their business associates) to safeguard Protected Health Information (PHI) across 18 identifiers.
 - Entities beyond the covered entities now collect vast amounts of personal health data. These companies can collect, store, and sell patient data with little oversight.
- Rise in Data Breaches:** Healthcare data breaches have tripled over the last decade. Phishing, ransomware, and denial-of-service attacks are the most common methods. The average healthcare breach costs approximately **\$8 million**, with per-record costs exceeding **\$400**.
- Epic Systems v. GuardDog Telehealth (2026):** GuardDog allegedly exploited healthcare systems to improperly access thousands of patient records for commercial purposes.
 - Underscores how existing regulations have failed to keep pace with an increasingly connected digital health ecosystem.

Legal Challenges

- HIPAA Privacy Rule (45 CFR Part 160 and Subparts A and E of Part 164)**
 - Specifies the specific "covered entities" that are required to comply with HIPAA regulation.
 - Problem:** In the digitized age, however, the healthcare ecosystem has expanded beyond these simple entities to watches, apps, home sensors, and patient portals.
 - Result:** Many organizations and companies that make up the healthcare ecosystem are not covered by HIPAA, increasing risk for privacy violations.
- Federal vs State Law** → the absence of new federal regulation to fill the gaps present in HIPAA has led to state regulation such as Washington's "My Health My Data Act."
 - Problem:** Leads to "data segmentation issues," which occur because healthcare organizations operating across multiple state jurisdictions must separate data into distinct camps: those regulated solely by HIPAA and those regulated by state law. This makes for severe operational complexity, as the need to comply with multiple, often contradictory, state laws drives up legal, administrative, and technological costs.

Ethical Implications

- Violation of patient confidentiality and erosion of trust:** Unauthorized access or use of patient data is inherently harmful, as it violates the fundamental principle of confidentiality that underpins the patient-provider relationship. In healthcare, confidentiality is not just a legal requirement but a core moral obligation tied to patient autonomy, dignity, and trust. Thus, the nonconsensual sharing and use of patient data significantly harms patients' sense of control over their own information, violating the principle of informational privacy and, more broadly, undermining trust in the healthcare system itself.
- Risk of re-identification and exploitation of sensitive patient data:** Privacy and confidentiality in healthcare give rise to multiple ethical implications, as patient records often are linked to sensitive information regarding one's identity. As patient records often contain strictly personal information, such as immigration status, sexual orientation, and mental health history, individuals can frequently be reidentified from supposedly deidentified datasets, which further exposes them to discrimination, stigmatization, or misuse of sensitive information. While this itself goes against the right to confidentiality and anonymization of healthcare, it becomes particularly concerning for vulnerable populations with marginalized identities, who may face unequal treatment or targeted exploitation if their data are exposed.

Solutions

- Expand the authority of the Federal Trade Commission (FTC) to serve as the primary regulator of digital health data beyond HIPAA**
 - Extend jurisdiction to third-party apps, wearables, and telehealth platforms, redefine "protected health data" to include non-HIPAA-covered sources, close accountability gaps for entities currently outside federal oversight
- Give the FTC rulemaking power to set national privacy standards (consent, data minimization, limited data sharing, cybersecurity) backed by enforcement and penalties**
 - Mandate transparent, informed user consent, require data minimization (only collect what is necessary), restrict third-party data sharing, enforce strong cybersecurity protections, impose penalties for noncompliance
- Create a unified system with certifications and safe harbor incentives to reduce regulatory fragmentation while strengthening accountability and trust in digital healthcare**
 - Provide clear, standardized benchmarks companies must meet to qualify for certification, offer legal protection from certain liabilities for certified organizations, use certification status to guide enforcement priorities and audits



References

Hall JL, McGraw D. For telehealth to succeed, privacy and security risks must be identified and addressed. *Health Aff (Millwood)*. 2014;33(2):216-221.
 Theodoris K. Siting S. Health Information Privacy Laws in the Digital Age: HIPAA Doesn't Apply. *Perspect Health Inf Manag*. 2020 Dec 7;18(Winter 11):PMID: 33633522; PMCID: PMC7883355.
 Chuvpilo, Varsha, et al. "Ethical Issues in Patient Data Ownership." *Interactive Journal of Medical Research*. JMIR Publications Inc., Toronto, Canada, www.ijmr.com/2023/2/22268.
 Accessed 16 Apr. 2026.

A Cost Analysis of Healthcare Sector Data Breaches: Health Sector Cybersecurity Coordination Center (HC3) HC3g/HHS.GOV. Executive Summary. 2019.
 Susan Li, Kamalakar Suriani, Nishant Prabhakaran. *Cyber-Attacks on Hospital Systems: A Narrative Review*. The American Journal of Geriatric Psychiatry: Open Science, Education, and Practice, Volume 7, 2023. Pages 36-39. ISSN 2950-3668. <https://doi.org/10.1016/j.amjger.2023.01.002>.
 Stipulation re: Judgment and Permanent Injunction. *Epic Systems Corp. et al. v. Health Gorilla, Inc. et al.* No. 2:26-cv-00321 (C.D. Cal. Mar. 13, 2026)